



axialoop



Evalis

EvalisDesk

Specifiche Funzionali del Sistema

Gestionale CRM sumisuraperOrganismi
di Certificazione ISO

Versione	1.0
Data	Aprile 2026
Sviluppato da	axialoop
Stack	React 18 · TypeScript 5 · Supabase · PostgreSQL 15
Utenti	5 utenti simultanei — 3 ruoli (Admin, Responsabile, Operatore)
Accesso	Browser web, nessuna installazione richiesta

1. Panoramica del Sistema

EvalisDesk è un gestionale web full-stack sviluppato interamente su misura per la gestione operativa di un organismo di certificazione ISO. Il sistema copre l'intero ciclo di vita di una pratica di certificazione: dall'apertura del contratto all'emissione del certificato, passando per la pianificazione dell'audit, la gestione documentale, le firme e il monitoraggio delle sorveglianze.

L'architettura è costruita attorno a un principio fondamentale: la logica di business risiede nel database, non nel frontend. Questo significa che le regole operative — workflow, prerequisiti, transizioni di fase, generazione automatica dei dati — sono implementate come trigger e funzioni PostgreSQL che operano indipendentemente dal codice applicativo. Qualsiasi client che tenti di interagire con il database, incluse chiamate API dirette, è soggetto alle stesse regole.

Il frontend è l'interfaccia. Il database è la legge.

1.1 Entità Principali

Il sistema gestisce quattro entità operative primarie e un insieme di entità di supporto:

Entità	Descrizione	Relazioni chiave
Pratica	Unità di lavoro centrale. Rappresenta un contratto di certificazione per un cliente su una norma specifica.	Appartiene a Cliente, ha Norme (M:N), è assegnata a un Utente, ha Allegati, Messaggi, Promemoria, Storico
Cliente	Anagrafica aziendale con dati ISO specifici: codice EA, NACE/ATECO, numero dipendenti.	Ha molte Pratiche, può essere gestito da un Consulente
Consulente	Intermediario esterno. Può essere associato a una Pratica come canale di acquisizione.	Collegato a Pratiche e a Norme di sua competenza
Utente	Operatore interno del sistema con ruolo (Admin / Responsabile / Operatore).	Assegnato a Pratiche, destinatario di Notifiche, autore di Messaggi
Norma	Catalogo preconfigurato di 17 norme ISO/EN. Integrità referenziale con ON UPDATE CASCADE.	Collegata a Pratiche, Utenti responsabili, Consulenti

2. Workflow Pratiche — Pipeline a 6 Stadi

Il workflow è la colonna vertebrale del sistema. Ogni pratica attraversa obbligatoriamente una sequenza di fasi definita. Non è possibile saltare fasi, invertire l'ordine di più di un passo, né far avanzare una pratica senza che i prerequisiti della fase siano soddisfatti.

La sequenza è: Contratto Firmato → Programmazione Verifica → Richiesta Proforma → Elaborazione Pratica → Firme → Completata.

#	Fase	Comportamento del sistema
1	Contratto Firmato	Apertura della pratica. Vengono registrati i dati anagrafici del cliente, la norma di certificazione, il tipo di ciclo (certificazione iniziale, sorveglianza o ricertificazione), il referente e l'eventuale consulente associato. Il sistema genera automaticamente un numero pratica univoco nel formato CERT-AAAA-XXXX, protetto da lock concorrenza per garantire unicità anche con più utenti simultanei. Fase di pianificazione operativa. Vengono registrati la data dell'audit, la sede di
2	Programmazione Verifica	verifica e l'auditor assegnato. Nessun avanzamento alla fase successiva è possibile senza che la data di verifica sia presente — vincolo imposto direttamente dal database, non aggirabile. Il sistema traccia la richiesta e l'emissione della proforma fattura. I timestamp di
3	Richiesta Proforma	richiesta e di emissione vengono registrati automaticamente. L'avanzamento alla fase successiva è bloccato finché la proforma non risulta emessa — validazione server-side, non client-side. Fase di raccolta documentale. Il sistema traccia il flag di ricezione documenti con timestamp. Finché i documenti non risultano ricevuti, il workflow blocca qualsiasi
4	Elaborazione Pratica	avanzamento verso la fase Firme — anche se l'operatore tenta di forzare l'aggiornamento via API diretta. Fase conclusiva di firma della documentazione di certificazione. Da questa fase è possibile completare la pratica. Tutti i flag di fasi precedenti sono a questo punto
5	Firme	protetti da un secondo trigger che impedisce di resettarli a false — l'integrità del percorso è permanente. Al completamento, il sistema esegue automaticamente nella stessa transazione di database: (1) imposta i campi data_completamento e flag completata, (2) genera un promemoria di sorveglianza a +365 giorni, (3) registra l'evento nello storico fasi.
✓	Completata	Tutto avviene atomicamente — o tutto o niente.

2.1 Cicli Certificativi Supportati

Ogni pratica è classificata con uno dei quattro cicli certificativi del dominio ISO:

Ciclo	Descrizione operativa
Certificazione	Prima certificazione del cliente su una norma. Ciclo completo dalla raccolta documenti all'emissione del certificato triennale.
Prima Sorveglianza	Prima verifica annuale post-certificazione. Verifica il mantenimento dei requisiti. Non emette nuovo certificato.
Seconda Sorveglianza	Seconda verifica annuale. Chiude il ciclo triennale prima della ricertificazione.

Ricertificazione	Rinnovo completo del certificato alla scadenza triennale. Equivale operativamente a una nuova certificazione.
------------------	---

2.2 Trigger di Validazione Database

Il comportamento del workflow è interamente governato da sei trigger PostgreSQL attivi sul database. Nessuno di questi è replicato o sostituibile dal frontend — operano come strato di enforcement definitivo:

Trigger	Evento	Comportamento
<i>genera_numero_pratica</i>	BEFORE INSERT su pratiche	Genera il numero CERT-AAAA-XXXX con advisory lock PostgreSQL che serializza gli inserimenti concorrenti. Nessun numero duplicato è possibile, nemmeno con più utenti che aprono pratiche in simultanea.
<i>validate_fase_transition</i>	BEFORE UPDATE OF fase su pratiche	Valida ogni transizione di fase. Rifiuta salti di più di una fase, retrocessioni di più di un passo e qualsiasi modifica su pratiche non attive. Controlla i prerequisiti specifici per ogni fase (data verifica, proforma emessa, documenti ricevuti). Opera lato database: impossibile aggirare anche con chiamate API dirette.
<i>protect_fase_flags</i>	BEFORE UPDATE su pratiche	Impedisce il reset dei flag di fasi già superate. Una volta che proforma_emessa è true in fase 4+, non può tornare false. Idem per documenti_ricevuti in fase 5+. Garantisce l'integrità retroattiva del percorso.
<i>on_pratica_completata</i>	BEFORE UPDATE OF fase su pratiche	Al passaggio in fase 'completata': crea automaticamente nella stessa transazione il promemoria di sorveglianza a +365 giorni, con testo che include le norme della pratica. Imposta il flag sorveglianza_reminder_creato per evitare duplicati.
<i>log_cambio_fase</i>	AFTER UPDATE OF fase su pratiche	Registra ogni cambio di fase nello storico_fasi con fase precedente, fase nuova, utente e timestamp. Trigger AFTER: scrive solo se la transizione ha superato validate_fase_transition. Lo storico è append-only — nessun ruolo ha permessi UPDATE/DELETE su storico_fasi.
<i>update_updated_at</i>	BEFORE UPDATE su pratiche, clienti	Aggiorna automaticamente il campo updated_at ad ogni modifica. Garantisce tracciabilità temporale senza dipendere dal codice applicativo.

Ogni tentativo di bypassare il workflow — incluse chiamate API dirette con chiave anonima valida — viene rifiutato dal database con un errore esplicito. Il frontend può pre-validare per migliorare l'esperienza utente, ma non è mai la fonte di verità.

2.3 Quality Assurance e Verifica dei Trigger

Ogni trigger PostgreSQL descritto nella sezione 2.2 è coperto da una suite di test automatici eseguiti su un database di staging dedicato, isolato dall'ambiente di produzione. I test verificano sia il comportamento atteso (transizioni valide) sia il comportamento di rifiuto (tentativi di salto di fase, reset di flag protetti, inserimenti concorrenti). La suite viene eseguita automaticamente a ogni rilascio, garantendo che nessuna modifica al codice o allo schema possa alterare silenziosamente la logica di workflow.

La copertura minima garantita per i trigger critici è la seguente:



Trigger	Scenari testati	Copertura
genera_numero_pratica	Unicità seriale, inserimenti concorrenti simulati	Positivo + concorrenza
validate_fase_transition	Ogni transizione valida, salti di fase, retrocessioni, prerequisiti mancanti, API diretta	Positivo + 5 scenari di rifiuto
protect_fase_flags	Reset di flag già impostati, tentativo via API diretta	Rifiuto garantito
on_pratica_completata	Creazione promemoria sorveglianza, atomicità della transazione, assenza di duplicati	Atomico + idempotente

3. Moduli Funzionali

3.1 Dashboard KPI

La dashboard è la schermata principale del sistema. Si aggiorna automaticamente ogni 5 minuti senza ricaricare la pagina. I dati sono differenziati per ruolo: Admin e Responsabile vedono il quadro globale, l'Operatore vede esclusivamente i propri dati.

Sezione	Contenuto	Comportamento
KPI Cards (4)	Pratiche Attive, Scadenze Critiche <15gg, Completate nel mese, Pratiche Bloccate.	Ogni card è cliccabile e porta alla lista pratiche filtrata per quella metrica. Mostra delta rispetto al mese precedente.
Scadenze Immediate	Lista compatta delle 5 pratiche con scadenza più vicina.	Colonne: cliente, norma, giorni rimanenti (badge colorato), fase attuale, accesso diretto.
Distribuzione per Fase	Conteggio pratiche per ciascuna delle 6 fasi.	Visione istantanea della distribuzione del carico operativo.
Pratiche Assegnate	Lista pratiche attive assegnate all'utente corrente.	Visibile solo agli Operatori. Admin e Responsabile vedono la distribuzione globale.
Ultime Attività	Feed cronologico degli ultimi 10 eventi di sistema: chi ha fatto cosa su quale pratica e quando.	Aggiornato in tempo reale. Fonte: tabella storico_fasi + eventi notifiche.

3.2 Sistema di Notifiche Real-Time

Il sistema di notifiche è costruito su WebSocket tramite Supabase Realtime. Le notifiche sono recapitate istantaneamente a ogni utente connesso interessato all'evento. La subscription è filtrata per destinatario a livello database: nessun utente riceve notifiche destinate ad altri.

Eventi che generano notifiche automatiche

- Avanzamento o retrocessione di fase di una pratica
- Assegnazione o riassegnazione di una pratica a un operatore
- Richiesta o emissione della proforma
- Ricezione documenti confermata
- Promemoria scaduto (generato dal job notturno)
- Completamento pratica

Architettura di resilienza

La connessione WebSocket è monitorata continuamente con un heartbeat ogni 30 secondi. In caso di interruzione, il sistema implementa tre livelli di recupero:

- Tentativo di riconnessione automatica immediata
- Attivazione di un polling fallback ogni 60 secondi se la riconnessione non avviene
- Indicatore visivo in tempo reale dello stato della connessione (verde / arancione lampeggiante / rosso)

Le notifiche con tipo critico o richiesta generano automaticamente un toast visivo in alto a destra con auto-dismiss a 5 secondi, indipendentemente dalla schermata aperta.

3.3 Gestione Allegati

Ogni pratica dispone di un'area allegati con upload drag-and-drop. I file sono archiviati su Supabase Storage con path strutturato per pratica: `allegati-pratiche/{praticald}/{uuid}-{nome_originale}`.

Funzione	Dettaglio tecnico
Upload	Drag-and-drop o selezione file. Barra di avanzamento in tempo reale. Validazione client: max 50 MB, tipi MIME ammessi. Metadati salvati in tabella allegati con fase di riferimento, dimensione, tipo e utente che ha caricato.
Download	Genera un URL firmato con scadenza 5 minuti. Dopo la scadenza il link non è più valido. Non esiste accesso diretto al file senza autenticazione.
Sicurezza	Policy Supabase Storage che consentono la lettura solo agli utenti che hanno accesso alla pratica corrispondente. Nessun accesso anonimo.
Eliminazione	Disponibile per chi ha caricato il file o per l'Admin. Rimuove sia il record in tabella che il file fisico dallo storage nella stessa operazione.
Associazione	Ogni allegato è associabile a una fase specifica della pratica, consentendo di contestualizzare la documentazione nel percorso certificativo.

3.4 Feed Messaggi Interno

Ogni pratica ha un feed di messaggi interni strutturato per tipo: commento, richiesta, risposta, sistema. I messaggi del tipo sistema sono generati automaticamente dagli eventi di workflow. Gli altri tipi sono scritti dagli operatori.

Il feed supporta messaggi con destinatario specifico (comunicazione privata tra due utenti nel contesto della pratica) o messaggi broadcast visibili a tutti i membri del team. I messaggi si aggiornano in tempo reale tramite Supabase Realtime. Gli allegati possono essere collegati direttamente a un messaggio.

3.5 Gestione Scadenze

La pagina Scadenze aggrega tutte le pratiche attive con data di scadenza e le ordina per urgenza crescente. Le pratiche sono classificate in tre fasce:

Fascia	Criterio	Presentazione visiva
Critica	Scadenza entro 15 giorni	Badge rosso. Appare nella KPI card 'Scadenze Critiche' della dashboard.
Attenzione	Scadenza tra 16 e 45 giorni	Badge giallo.
Nella norma	Scadenza oltre 45 giorni	Badge verde.

La tabella scadenze include una checklist operativa aggiornabile inline: i flag `data_verifica` impostata, `documenti_ricevuti`, `proforma_emessa` e `completata` sono modificabili con un singolo click direttamente nella riga, con salvataggio immediato su database senza aprire la scheda della pratica.

■ 3.6 Promemoria e Sorveglianza Automatica

Il modulo promemoria funziona su due livelli: manuale e automatico.

Promemoria manuali

Gli operatori possono creare promemoria su qualsiasi pratica, assegnarli a sé stessi o ad altri utenti, con data di scadenza. La pagina Promemoria globale mostra tutti i promemoria attivi dell'utente corrente ordinati per scadenza.

Sorveglianza automatica

Al completamento di ogni pratica, il trigger `on_pratica_completata` crea nella stessa transazione atomica un promemoria di sorveglianza con scadenza a +365 giorni. Il testo del promemoria è generato dinamicamente e include le norme certificate e il numero della pratica.

Job notturno (Edge Function schedulata)

Un job automatico eseguito ogni giorno alle 08:00 (ora italiana) svolge due funzioni: (1) individua pratiche completate senza promemoria di sorveglianza e li crea retroattivamente come safety-net, (2) identifica i promemoria in scadenza o scaduti e genera notifiche corrispondenti verso i destinatari. Il job opera server-side indipendentemente dagli utenti connessi.

■ 3.7 Anagrafica Clienti e Consulenti

L'anagrafica clienti include oltre ai dati aziendali standard i campi specifici del dominio certificativo ISO:

- Codice EA (codice dell'attività economica per la certificazione)
- Codice NACE/ATECO (classificazione attività, rilevante per la durata degli audit)
- Numero di dipendenti (parametro che incide sul calcolo della durata minima dell'audit secondo gli schemi ISO)

L'anagrafica consulenti tiene traccia degli intermediari esterni con le norme di loro competenza, consentendo di filtrare e associare il consulente corretto a ogni pratica.

4. Architettura di Sicurezza

4.1 Row Level Security (RLS)

Ognitabella del database ha la Row Level Security abilitata. Le policy definiscono con precisione quali righe ciascun ruolo può leggere, inserire, modificare o eliminare. La funzione helper `get_user_role()` è dichiarata SECURITY DEFINER con REVOKE su PUBLIC e GRANT solo agli utenti autenticati — impedisce che gli utenti leggano direttamente la propria riga di profilo per determinare il ruolo.

R u o l o	Descrizione accessi e permessi
Admin	Accesso completo senza restrizioni. Vede e modifica tutte le pratiche, tutti gli utenti, tutte le configurazioni. Può annullare e sospendere pratiche con registrazione del motivo e del timestamp. Unico ruolo con accesso alla configurazione del sistema.
Responsabile	Visibilità completa su tutte le pratiche del sistema. Può modificare pratiche non assegnate ad altri operatori. Non accede alla gestione utenti e configurazioni di sistema.
Operatore	Accesso esclusivamente alle pratiche con il proprio UUID nel campo <code>assegnato_a</code> . Questa restrizione è applicata da una Row Level Security policy sul database: anche accedendo direttamente all'API Supabase con credenziali valide, un operatore non può leggere né scrivere dati di pratiche altrui.

La separazione dei dati tra operatori non è una scelta di interfaccia — è un vincolo fisico del database. Un operatore con credenziali valide che chiama direttamente l'API Supabase riceve solo e soltanto le righe che la RLS gli permette di vedere.

4.2 Sicurezza degli Allegati

I file allegati non sono accessibili via URL statico. L'unico modo per accedere a un file è generare un URL firmato tramite la funzione Supabase Storage, che: (1) verifica l'autenticazione dell'utente richiedente, (2) verifica che l'utente abbia accesso alla pratica corrispondente, (3) genera un URL con firma crittografica valida 5 minuti. Dopo la scadenza, il link non funziona.

4.3 Sicurezza del Frontend

Il frontend non contiene mai la chiave `service_role` di Supabase — solo la chiave anonima pubblica `VITE_SUPABASE_ANON_KEY`. Tutte le operazioni privilegiate avvengono tramite funzioni SECURITY DEFINER nel database. Il Content Security Policy è configurato sull'Nginx del VPS per prevenire injection di script esterni.

4.4 Storico Immutabile

La tabella `storico_fasi` è append-only per design: nessun ruolo, incluso Admin, ha permessi UPDATE o DELETE su questa tabella. Ogni cambio di fase è permanentemente registrato con utente, timestamp, fase precedente e fase nuova. Questo crea un audit trail inviolabile dell'intero percorso di ogni pratica.

5. Stack Tecnologico

Il sistema è costruito interamente con tecnologie open-source o con licenze permissive (MIT, Apache 2.0). Nessuna dipendenza proprietaria che possa generare lock-in tecnologico o costi di licenza aggiuntivi.

Layer	Tecnologia	Ruolo nel sistema
Frontend	React 18 + TypeScript 5	Interfaccia web moderna, tipizzazione stretta (zero any), compilazione statica senza runtime server.
UI Components	Shadcn UI + Tailwind CSS	Componenti accessibili e stilizzati, coerenti su tutti i browser e dispositivi.
State & Data	TanStack Query v5	Cache intelligente, refetch automatico, optimistic updates. I dati rimangono sincronizzati senza ricaricare la pagina.
Validazione	React Hook Form + Zod	Validazione schema-based sia client-side che server-side.
Database	PostgreSQL 15 via Supabase	Nessun dato malformato raggiunge il database. Database relazionale con trigger, funzioni, advisory lock, Row Level Security e indici ottimizzati.
Auth	Supabase Auth	Gestione sessioni, token JWT, refresh automatico. Nessuna credenziale nel codice.
Storage	Supabase Storage	File archiviati su object storage con policy di accesso granulari per pratica.
Realtime	Supabase Realtime (WebSocket)	Notifiche e aggiornamenti istantanei tra tutti gli utenti connessi, con heartbeat e fallback polling.
Edge Functions	Deno (Supabase Edge Functions)	Job schedulato notturno per promemoria scaduti e safety-net sorveglianza. Eseguito server-side, indipendente dai client connessi.
Hosting	Hetzner VPS + Nginx	Server dedicato in Europa, build statica servita via Nginx con Content Security Policy headers.
Routing	Cloudflare Tunnel / DuckDNS	Accesso HTTPS senza esporre porte, senza costo di dominio dedicato.

5.1 Database — Schema

Il database PostgreSQL 15 comprende 11 tabelle principali, con le seguenti caratteristiche di design:

- UUID come chiavi primarie su tutte le tabelle (gen_random_uuid())
- Soft delete tramite flag attivo = false dove applicabile
- Campi created_at / updated_at su ogni tabella, aggiornati da trigger
- Tabelle di giunzione con FK ON UPDATE CASCADE per le relazioni norme (pratiche_norme, responsabili_norme, consulenti_norme)
- Indici composti su (fase, assegnato_a), (stato, fase) e (destinatario_id, letta) per le query più frequenti
- Advisory lock pg_advisory_xact_lock per la generazione serializzata dei numeri pratica

5.2 Infrastruttura

Il sistema è ospitato su infrastruttura dedicata e isolata:

Componente	Specifiche	Costo mensile
VPS Hetzner CX22	Ubuntu 24.04, 2 vCPU, 4 GB RAM, 40 GB SSD — data center EU-Central (Germania)	7 €
Backup automatici	Snapshot giornalieri del VPS (politica Hetzner)	0,91 €
Supabase Cloud Pro	Database PostgreSQL, Auth, Storage, Realtime, Edge Functions	25,00 €
DNS + HTTPS	DuckDNS o Cloudflare Tunnel — accesso HTTPS senza dominio dedicato Resend — tier gratuito fino a 3.000 email/mese	0 €
Email notifiche		0 €
Totale infrastruttura		~33-34 €/mese

5.3 Strategia di Backup e Recovery

Il sistema implementa una strategia di backup su due livelli indipendenti, garantendo la recuperabilità dei dati sia in caso di guasto infrastrutturale che in caso di corruzione logica del database.

Livello 1 — Snapshot VPS (Hetzner)

Hetzner esegue snapshot giornalieri dell'intero VPS (configurazione, codice applicativo, Nginx). Costo incluso nella voce backup automatici (0,91 €/mese). Consente il ripristino completo del server in caso di guasto hardware o errore di configurazione, con granularità giornaliera.

Livello 2 — Point-in-Time Recovery (Supabase Pro)

Supabase Cloud Pro include il Point-in-Time Recovery (PITR) del database PostgreSQL con finestra di 7 giorni e granularità al secondo. In caso di eliminazione accidentale di dati, corruzione logica o errore operativo, è possibile ripristinare il database a qualsiasi istante nei 7 giorni precedenti senza perdita di dati intermedi. Il PITR opera indipendentemente dagli snapshot VPS e copre esclusivamente il layer database, incluse tutte le tabelle, i trigger e lo storico fasi. Il ripristino avviene su un'istanza separata per consentire la verifica dei dati prima del rientro in produzione.

6. Catalogo Norme — 17 Standard Supportati

Il catalogo norme è preconfigurato nel database con i 17 standard più richiesti dagli organismi di certificazione italiani. Le norme sono entità referenziate con vincoli di integrità referenziale: non è possibile eliminare una norma in uso, e qualsiasi modifica al codice si propaga automaticamente a tutte le entità collegate tramite ON UPDATE CASCADE.

- ISO 9001 — Sistemi di gestione della qualità
- ISO 14001 — Gestione ambientale · ISO 45001 — Salute e sicurezza sul lavoro · ISO 27001 — Sicurezza delle informazioni · ISO 50001 — Gestione dell'energia · ISO 37001 — Sistemi anti-corruzione · ISO 39001 — Sicurezza stradale · ISO 14064-1 — Emissioni di gas serra · ISO 20121 — Sostenibilità degli eventi

- ISO 13009 — Operatori balneari
- ISO 30415 — Diversità e inclusione HR
- ISO 3834 — Qualità saldatura metalli
- EN 1090 — Strutture in acciaio e alluminio
- SA 8000 — Responsabilità sociale d'impresa
- PDR 125/2022 — Parità di genere
- PAS 24000 — Gestione sociale (SMS)
- ESG-EASI — Sostenibilità e responsabilità

Ogni norma è collegabile a pratiche, a utenti responsabili e a consulenti tramite tabelle di giunzione dedicate. Questo consente query come: "tutte le pratiche ISO 9001 assegnate a questo auditor" o "tutti i consulenti certificati su ISO 27001".



7. Accesso e Utilizzo

7.1 Modalità di Accesso

EvalisDesk è accessibile da qualsiasi browser moderno (Chrome, Firefox, Edge, Safari) senza installazioni. L'accesso avviene tramite URL HTTPS con autenticazione tramite email e password. Le sessioni sono gestite con token JWT con refresh automatico — l'utente rimane autenticato senza dover effettuare nuovamente il login a ogni visita.

7.2 Compatibilità

L'interfaccia è costruita con Tailwind CSS e componenti responsive. È utilizzabile su desktop, laptop e smartphone. Su dispositivi mobili l'interfaccia si adatta automaticamente al viewport, mantenendo la piena operatività di tutte le funzioni.

7.3 Configurabilità per Istanza

Il sistema è personalizzabile tramite variabili d'ambiente senza modificare il codice: nome dell'organismo (VITE_APP_NAME), denominazione visualizzata (VITE_CLIENTE_NAME), colore primario (VITE_PRIMARY_COLOR), URL del logo (VITE_LOGO_URL).

7.4 Proprietà del Codice Sorgente

Al completamento e al collaudo del sistema, l'integrità del codice sorgente viene trasferita integralmente al cliente. La consegna include il repository completo (frontend React/TypeScript, funzioni Edge, script di migrazione database e configurazioni infrastrutturali), le credenziali di accesso all'istanza Supabase e al VPS Hetzner intestate al cliente, e la documentazione tecnica necessaria per la gestione autonoma del sistema.

Il cliente può liberamente modificare, estendere, affidare a terzi la manutenzione o integrare il sistema con altri strumenti. axialoop non trattiene alcun diritto sul codice specifico sviluppato per questa commessa.

8. Conformità e Protezione dei Dati

Il sistema tratta dati aziendali di clienti e operatori nell'ambito di processi di certificazione ISO. Le scelte architetturali descritte in questo documento sono coerenti con i principi del Regolamento (UE) 2016/679 (GDPR) e con le prassi di sicurezza applicabili agli organismi di certificazione. Di seguito le misure implementate per ciascuna area di conformità.

Principio GDPR	Implementazione nel sistema
Minimizzazione dei dati	Il sistema raccoglie esclusivamente i dati necessari alla gestione del ciclo certificativo (art. 5.1.c GDPR). Nessun dato personale dei clienti finali dell'organismo viene trattato: le anagrafiche riguardano esclusivamente persone giuridiche.
Integrità e riservatezza	Tutti i dati sono cifrati in transito (HTTPS/TLS) e a riposo (cifatura Supabase a livello storage). La Row Level Security garantisce che ciascun operatore acceda esclusivamente ai dati di propria competenza (art. 25 GDPR — privacy by design).
Tracciabilità dei trattamenti	Lo storico fasi append-only costituisce un registro immutabile di ogni operazione sulle pratiche, con autore e timestamp. I campi updated_at aggiornati da trigger garantiscono la tracciabilità temporale di ogni modifica su clienti e pratiche (art. 5.1.f GDPR).
Localizzazione dei dati	Il VPS Hetzner è situato nel data center EU-Central (Germania). Supabase Cloud Pro può essere configurato sulla region eu-central-1 (Francoforte). Tutti i dati rimangono all'interno dello Spazio Economico Europeo, in conformità con l'art. 44 GDPR.
Controllo degli accessi	Il sistema di ruoli (Admin, Responsabile, Operatore) con separazione fisica via RLS implementa il principio del minimo privilegio. Le credenziali sono gestite tramite Supabase Auth con token JWT a scadenza: nessuna password è conservata in chiaro nel database.